

第九讲 HTTP协议与HTTPS协议



学习任务

- ✓ 了解HTTP协议与HTTPS协议
- ✓ 熟悉HTTP协议与HTTPS协议工作流程
- ✓ 抓包分析HTTP协议与HTTPS协议流量

HTTP协议基本知识

基本概念:

- ✓ HTTP(超文本传输协议)是用于在万维网服务器上传输超文本(HTML)到本地浏览器的传输协议
- ✓ 属于TCP/IP协议族的一员(HTML文件、图片、查询结构等)
- ✓ 基于传输层TCP的80号端口

HTTP协议基本知识

万维网服务:

- ✓ 借助多文档之间相互关联形成的超文本(Hypertext), 连成可相互参阅的WWW(World Wide Web,万维网)
- ✓ 采用C/S架构
- ✓ 客户机通过浏览器去请求, 从而在浏览器上就可以看到对应图形界面, 浏览器/服务器(B/S架构)

HTTP协议基本知识

万维网服务的软件:

- ✓ Windows server IIS (Windows平台)
- ✓ apache(多平台)
- ✓ tomcat(多平台)
- ✓ nginx(多平台)

.....

HTTP协议工作原理

(1) 在客户端使用浏览器通过URL向HTTP服务器发送请求

URL: (统一资源定位符), 由三部分组成

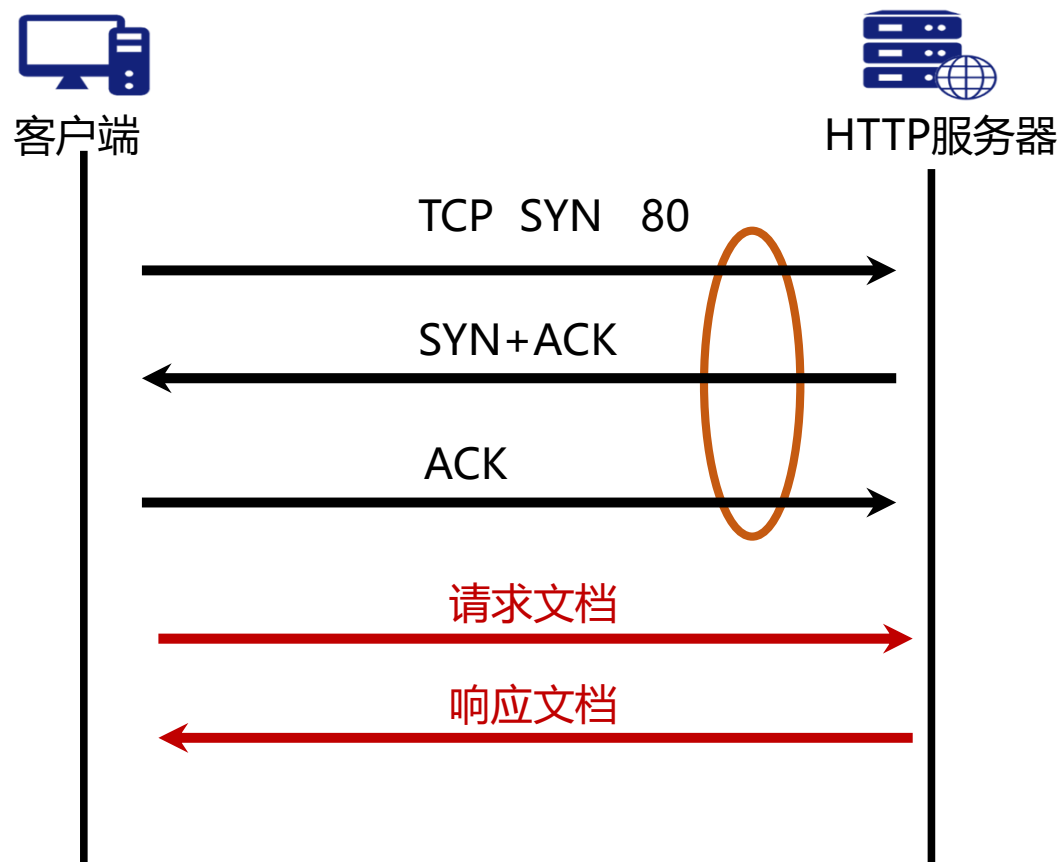
`https://www.xaut.edu.cn/zzjg/gljg.htm`

协议 主机和端口 (80) 文件名和路径

HTTP协议工作原理

- (2) Web服务器根据收到的请求直接向客户机响应信息
- (3) 针对于HTTP默认端口号是80端口，默认端口可以改(会影响客户机的访问，建议改为其他非标准端口)

HTTP协议交互过程



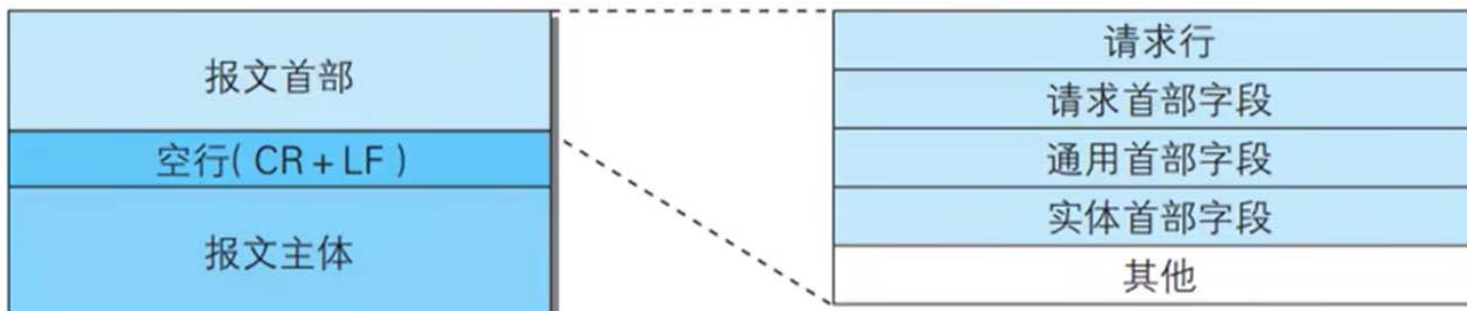
HTTP协议注意事项

- ✓ HTTP是无连接的：限制每次连接只处理一个请求。
- ✓ HTTP是独立的：只要客户端和服务端知道如何处理数据内容，任何类型的数据都可以通过HTTP发送。客户端以及服务器指定使用适合的 MIME-type(消息内容类型)。
- ✓ HTTP是无状态的：没有记忆能力，后续处理的内容需要用到前面内容时，就必须重传，每次连接传送的数据量比较大，从另一个方面来考虑，服务器不需要提供先前信息，应答就比较快。

第九讲 HTTP协议与HTTPS协议



HTTP协议请求报文格式



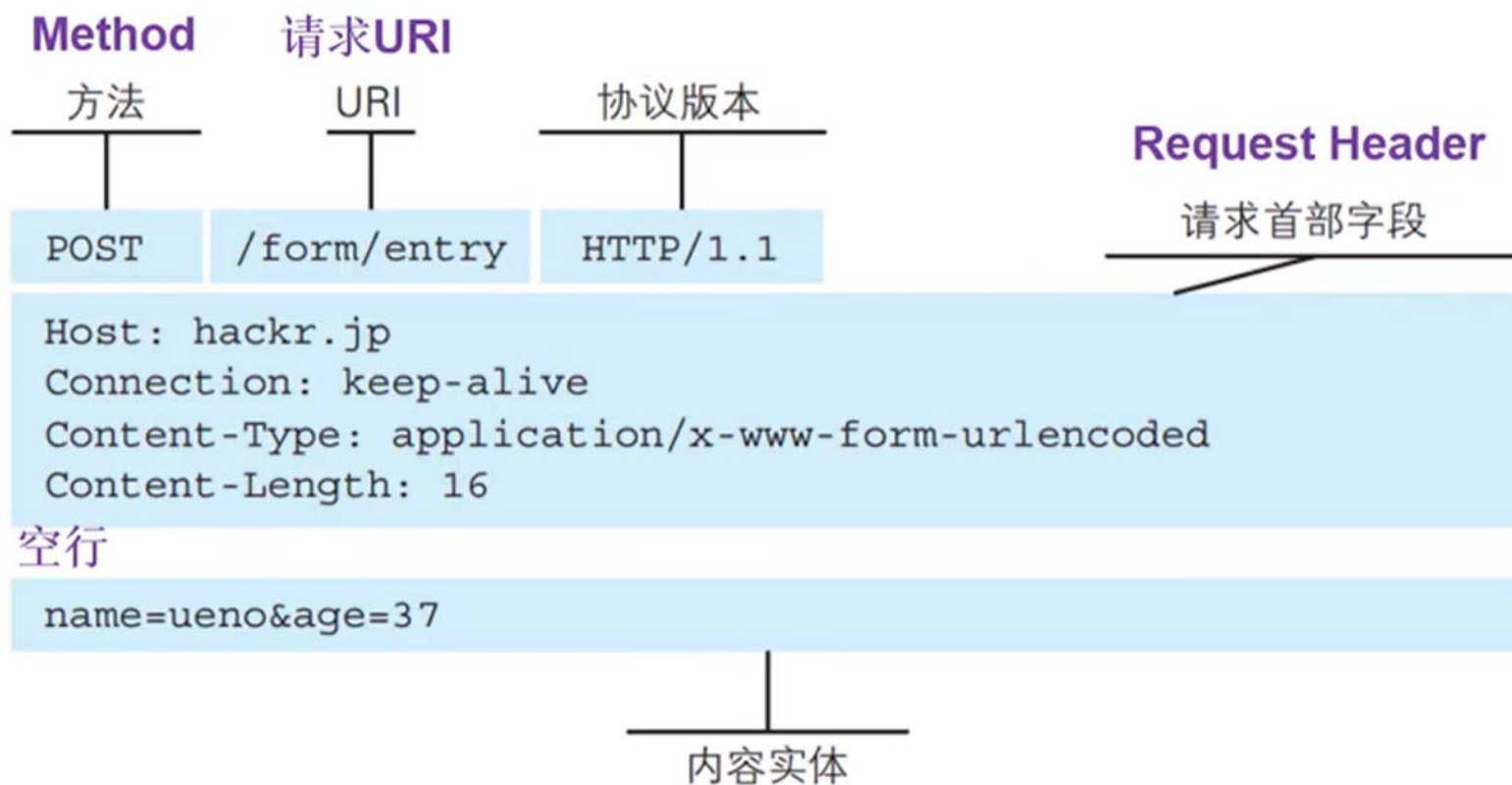
GET / HTTP/1.1	请求行
Host: hackr.jp User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; rv:13.0) Gecko/20100101 Firefox/13.0.1 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Language: ja,en-us;q=0.7,en;q=0.3 Accept-Encoding: gzip, deflate DNT: 1 Connection: keep-alive Pragma: no-cache Cache-Control: no-cache	各种首部字段
空行(CR + LF)	

第九讲 HTTP协议与HTTPS协议



西安理工大学
XI'AN UNIVERSITY OF TECHNOLOGY

HTTP协议请求报文格式



HTTP协议响应报文格式



第九讲 HTTP协议与HTTPS协议



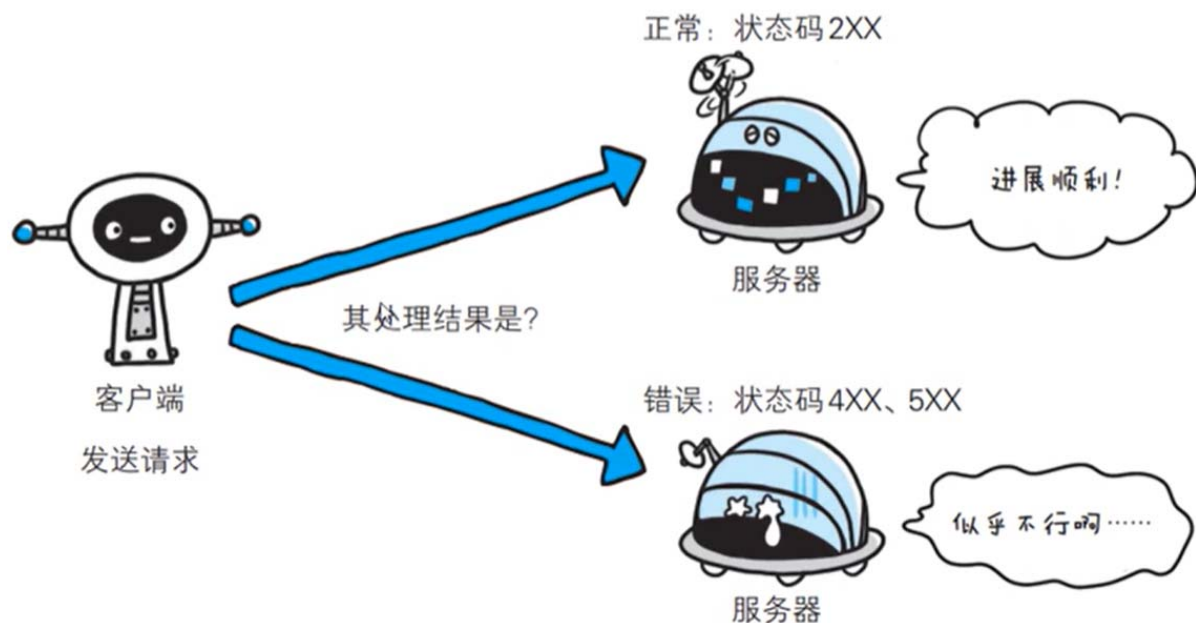
西安理工大学
XI'AN UNIVERSITY OF TECHNOLOGY

HTTP协议响应报文格式



HTTP协议状态码

状态码的职责是当客户端向服务器端发送请求时，**描述返回的请求结果**。
借助状态码，用户可以知道服务器端是**正常处理了请求还是出现了错误**。

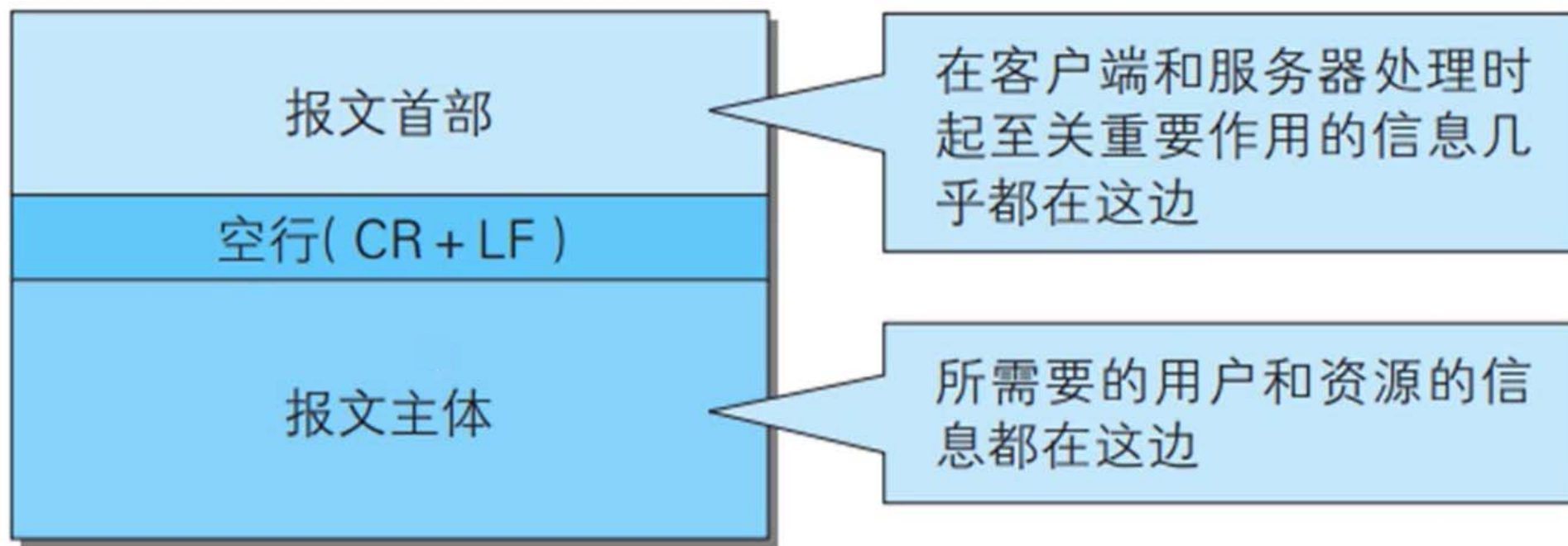


HTTP协议状态码

状态码类别：

	类别	原因短语
1XX	Informational (信息性状态码)	接收的请求正在处理
2XX	Success (成功状态码)	请求正常处理完毕
3XX	Redirection (重定向状态码)	需要进行附加操作以完成请求
4XX	Client Error (客户端错误状态码)	服务器无法处理请求
5XX	Server Error (服务器错误状态码)	服务器处理请求出错

HTTP协议报文首部



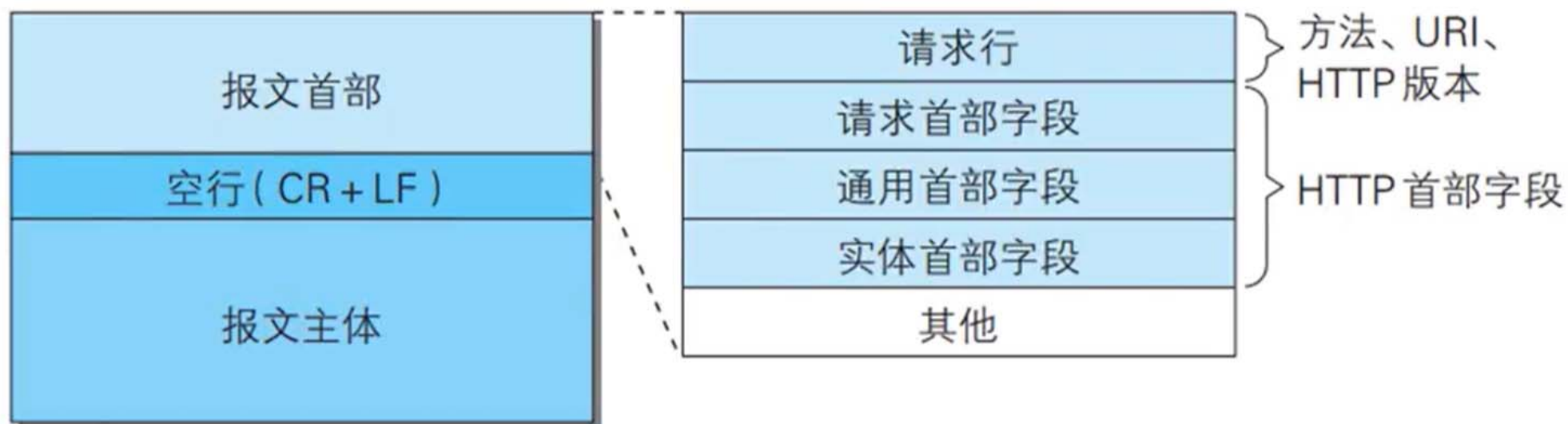
HTTP协议首部

首部作用：

- ✓ HTTP首部字段是构成HTTP报文的要素之一。在客户端与服务器之间以HTTP协议进行通信的过程中，无论是请求还是响应都会使用首部字段，它能起到传递额外重要信息的作用。
- ✓ 使用首部字段是为了给浏览器和服务器提供报文主体大小所使用的语言、认证信息等内容。

第九讲 HTTP协议与HTTPS协议

HTTP协议请求报文首部



第九讲 HTTP协议与HTTPS协议



西安理工大学
XI'AN UNIVERSITY OF TECHNOLOGY

HTTP协议请求报文首部

GET http://www.qytang.com/ HTTP/1.1

Host: www.qytang.com

Connection: keep-alive

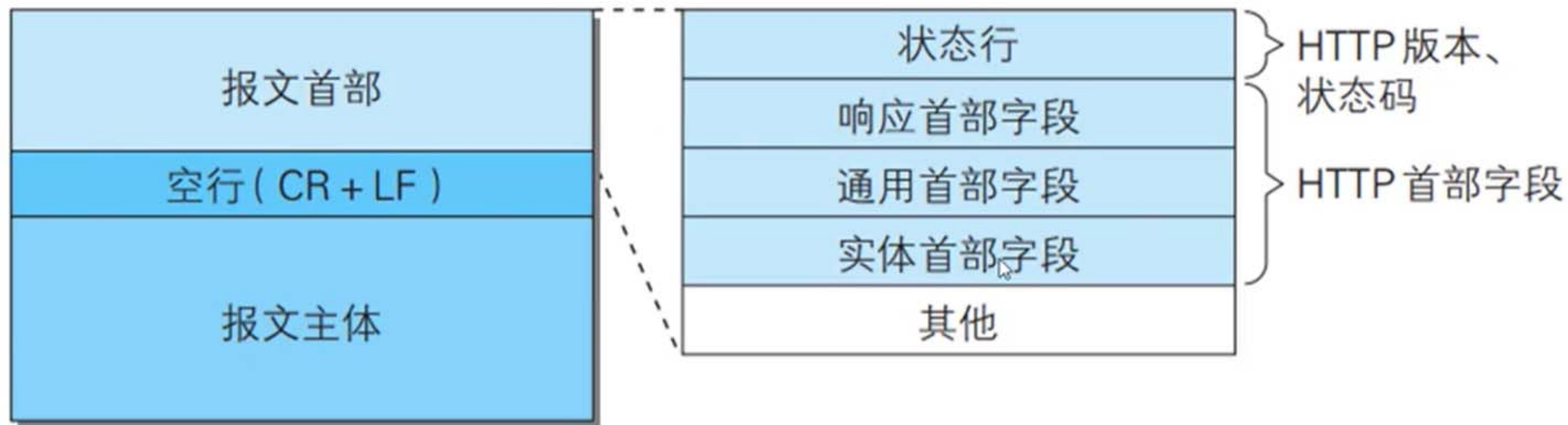
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8

User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/38.0.2125.122 Safari/537.36

Accept-Encoding: gzip,deflate,sdch

Accept-Language: zh-CN,zh;q=0.8

HTTP协议响应报文首部



HTTP协议响应报文首部

HTTP/1.1 **200 OK**

Date: Tue, 18 Oct 2016 02:15:08 GMT

Server: Apache/2.4.6 (CentOS) OpenSSL/1.0.1e-fips PHP/5.4.16

Last-Modified: Tue, 18 Oct 2016 02:11:03 GMT

ETag: "3e3-53f1a34515bc0"

Accept-Ranges: bytes

Content-Length: 995

Keep-Alive: timeout=5, max=100

Connection: Keep-Alive

Content-Type: text/html; charset=UTF-8

HTTP协议首部字段结构

HTTP 首部字段是由首部字段名和字段值构成的，中间用冒号 “:” 分隔。

首部字段名： 字段值

例如，在 HTTP 首部中以 Content-Type 这个字段来表示报文主体的对象类型

Content-Type: text/html

另外，字段值对应单个 HTTP 首部字段可以有多个值，如下所示。

Keep-Alive: timeout=15, max=100

HTTP协议首部字段结构

通用首部字段（General Header Fields）

请求报文和响应报文两方都会使用的首部。

请求首部字段（Request Header Fields）

从客户端向服务器端发送请求报文时使用的首部。补充了请求的附加内容、客户端信息、响应内容相关优先级等信息。

响应首部字段（Response Header Fields）

从服务器端向客户端返回响应报文时使用的首部。补充了响应的附加内容，也会要求客户端附加额外的内容信息。

实体首部字段（Entity Header Fields）

针对请求报文和响应报文的实体部分使用的首部。补充了资源内容更新时间等与实体有关的信息。

HTTP协议首部字段结构

通用首部:

首部字段名	说明
Cache-Control	控制缓存的行为
Connection	逐跳首部、连接的管理
Date	创建报文的日期时间
Pragma	报文指令
Trailer	报文末端的首部一览
Transfer-Encoding	指定报文主体的传输编码方式
Upgrade	升级为其他协议
Via	代理服务器的相关信息
Warning	错误通知

第九讲 HTTP协议与H

HTTP协议首部字段结

请求首部:

首部字段名	说明
Accept	用户代理可处理的媒体类型
Accept-Charset	优先的字符集
Accept-Encoding	优先的内容编码
Accept-Language	优先的语言（自然语言）
Authorization	Web 认证信息
Expect	期待服务器的特定行为
From	用户的电子邮箱地址
Host	请求资源所在服务器
If-Match	比较实体标记（ETag）
If-Modified-Since	比较资源的更新时间
If-None-Match	比较实体标记（与 If-Match 相反）
If-Range	资源未更新时发送实体 Byte 的范围请求
If-Unmodified-Since	比较资源的更新时间（与 If-Modified-Since 相反）
Max-Forwards	最大传输逐跳数
Proxy-Authorization	代理服务器要求客户端的认证信息
Range	实体的字节范围请求
Referer	对请求中 URI 的原始获取方
TE	传输编码的优先级
User-Agent	HTTP 客户端程序的信息



HTTP协议首部字段结构

响应首部:

首部字段名	说明
Accept-Ranges	是否接受字节范围请求
Age	推算资源创建经过时间
ETag	资源的匹配信息
Location	令客户端重定向至指定 URI
Proxy-Authenticate	代理服务器对客户端的认证信息
Retry-After	对再次发起请求的时机要求
Server	HTTP 服务器的安装信息
Vary	代理服务器缓存的管理信息
WWW-Authenticate	服务器对客户端的认证信息

HTTP协议首部字段结构

实体首部:

首部字段名	说明
Allow	资源可支持的 HTTP 方法
Content-Encoding	实体主体适用的编码方式
Content-Language	实体主体的自然语言
Content-Length	实体主体的大小（单位：字节）
Content-Location	替代对应资源的 URI
Content-MD5	实体主体的报文摘要
Content-Range	实体主体的位置范围
Content-Type	实体主体的媒体类型
Expires	实体主体过期的日期时间
Last-Modified	资源的最后修改日期时间

HTTPS协议首部字段结构

实体首部:

首部字段名	说明
Allow	资源可支持的 HTTP 方法
Content-Encoding	实体主体适用的编码方式
Content-Language	实体主体的自然语言
Content-Length	实体主体的大小（单位：字节）
Content-Location	替代对应资源的 URI
Content-MD5	实体主体的报文摘要
Content-Range	实体主体的位置范围
Content-Type	实体主体的媒体类型
Expires	实体主体过期的日期时间
Last-Modified	资源的最后修改日期时间



HTTPS协议学习任务

- ✓ 加密算法
- ✓ PKI体系(公钥基础设施)
- ✓ 证书, CA证书服务器
- ✓ 分析HTTPS流量 (分析TLS交互过程)

HTTPS协议基本知识

HTTP协议的不足：

- ✓ 通信使用明文，内容可能会被窃听
- ✓ 不验证通信方的身份，有可能遭遇伪装
- ✓ 无法证明报文的完整性，有可能信息已遭篡改

怎么避免HTTP
协议这些缺点



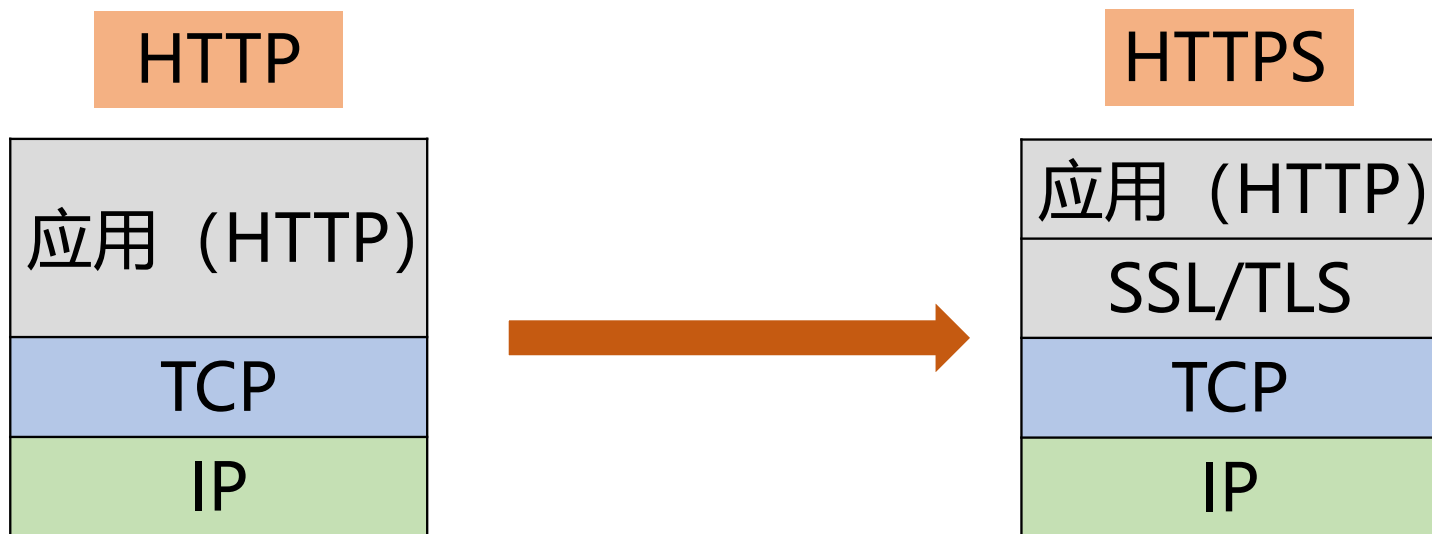
HTTPS协议

$\text{HTTPS} = \text{HTTP} + \text{加密} + \text{认证} + \text{完整性保护} = \text{HTTP} + \text{SSL/TLS}$

HTTPS协议基本知识

基本概念：

HTTPS是以安全为目标的HTTP通道，并不是独立于HTTP的一个全新协议，而是在HTTP协议的基础上，**添加了SSL/TLS握手以及数据加密传输**，也属于应用层协议。

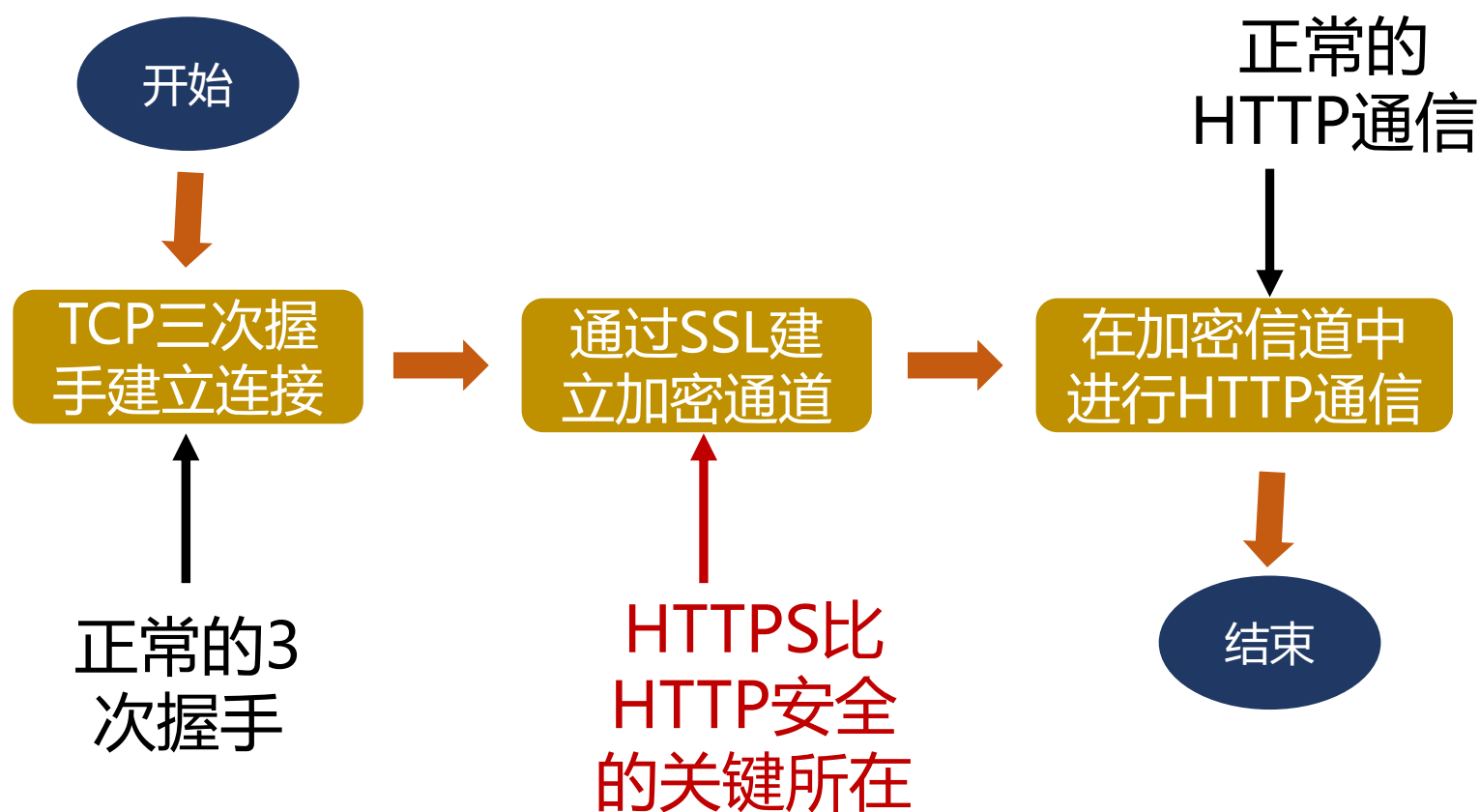


HTTPS协议基本知识

定义：

(全称: Hyper Text Transter Protocol over Secure Socket Layer),
是以安全为目标的HTTP通道, 在HTTP的基础上通过传输加密和身份认证保证了传输过程的安全性。

HTTPS协议工作流程





HTTPS协议基本知识

SSL与TLS关系

- ✓ 传输层安全协议
- ✓ SSL和TLS其实是一个协议
- ✓ SSL2.0版本 自SSL3.0版本后，更名为TLS1.0，目前最高版本TLS1.3，使用最为广泛的是TLS1.2版

HTTPS协议基本知识

SSL/TLS设计目标:

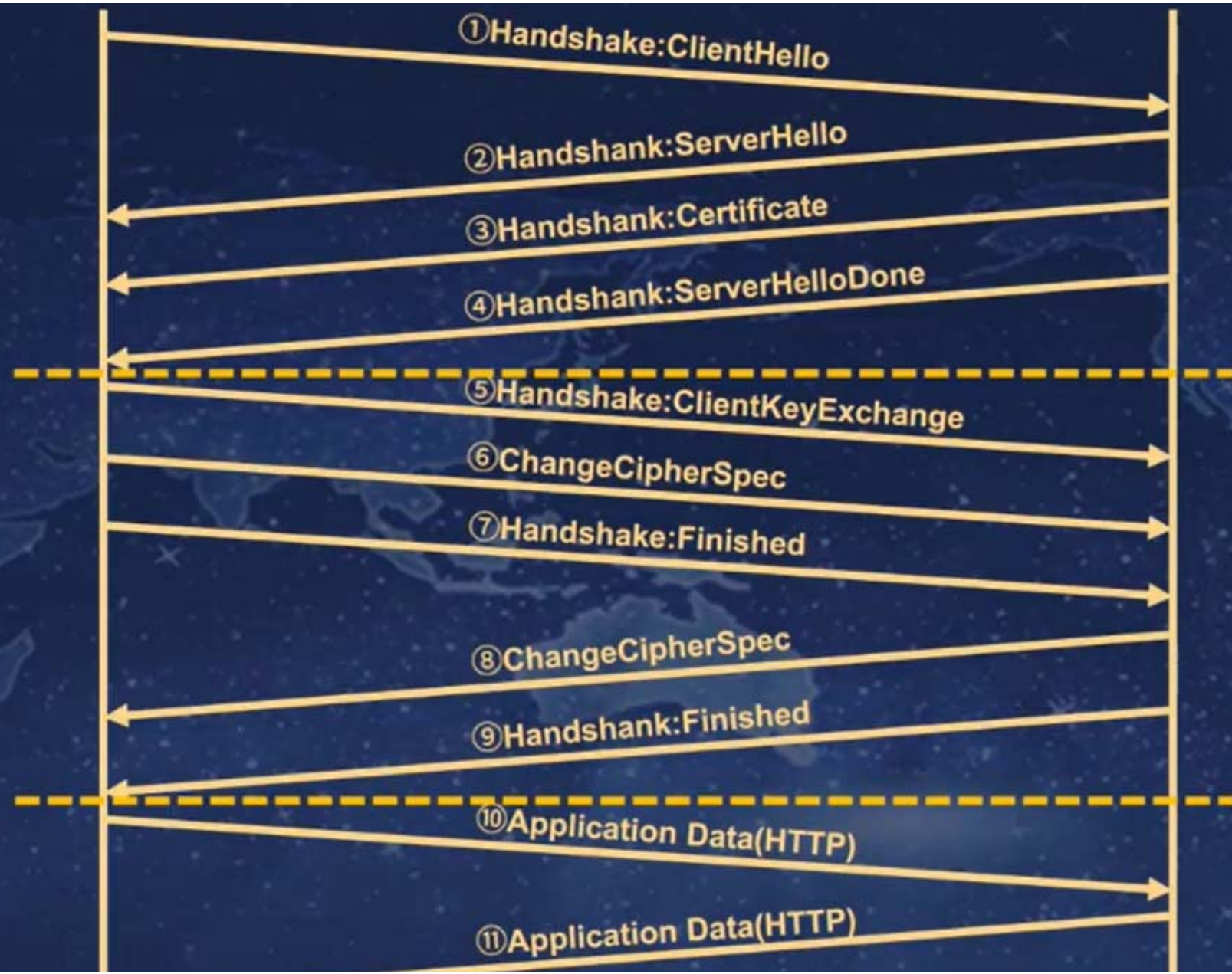
- ✓ 保密性：所有的信息都加密传输
- ✓ 完整性：校验机制
- ✓ 认证：双方都配备证书，防止冒充
- ✓ 互操作、通用性
- ✓ 可扩展高效率



Client



Server



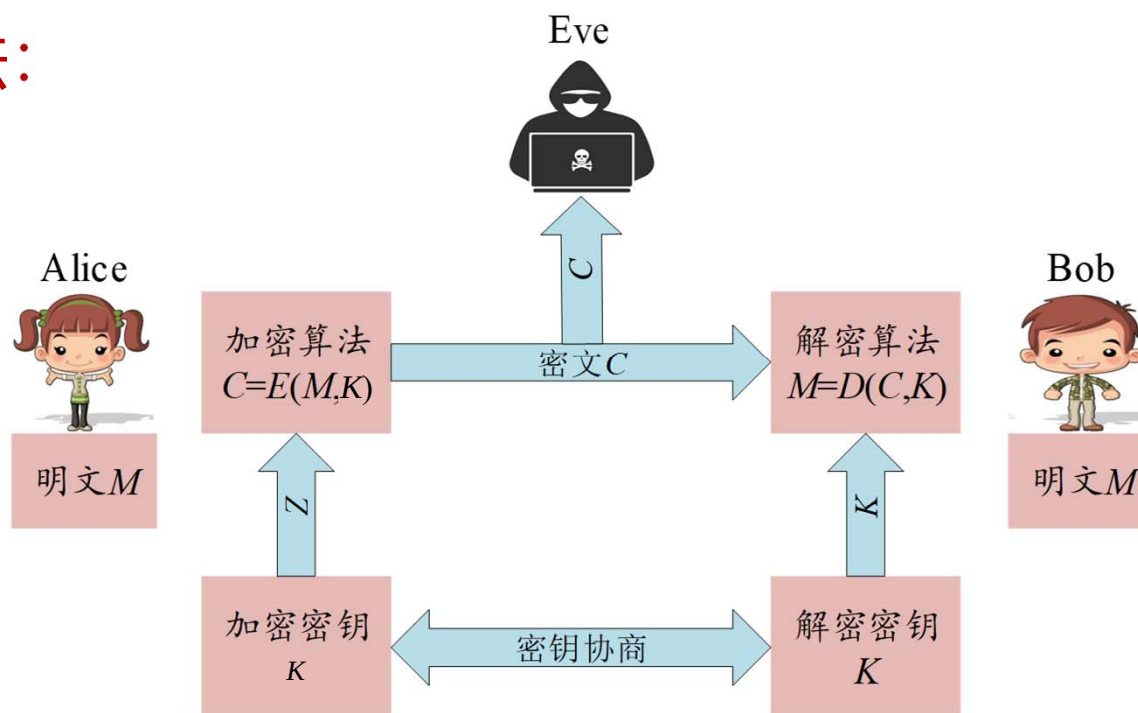
HTTPS协议基本知识

HTTPS协议优点:

- ✓ 在传输数据之前，客户端会和服务器端去**协商**数据在传输过程中的**加密算法**，包含自己的**非对称加密的密钥交换算法(RSA/DH)**，**数字签名摘要算法(MDS/SHA)**，加密传输数据的**对称加密算法(DES/3DES/AES)**。
- ✓ 客户端生成**随机的字符串**，通过协商好的非对称加密算法，使用**服务端的公钥对该字符串进行加密**，发送给服务端。服务端接收到之后，使用自己的私钥解密得到该字符串。在随后的数据传输当中，使用这个字符串作为密钥进行对称加密。

加密算法

对称加密算法:



加密算法

对称加密算法特点：

- ✓ 加密和解密的密钥相同
- ✓ 适用于明文数据量大的情况

对称加密算法存在的问题：

- ✓ 密钥如何传输问题
- ✓ 密钥管理的问题

常用的对称加密算法：

- ✓ DES/3DES
- ✓ AES
- ✓ RC（分组密码、流密码）
- ✓ IDEA（分组密码）
- ✓ SM1/4/7

第九讲 HTTP协议与HTTPS协议



加密算法

1、SM1是一种分组加密算法

对称加密算法中的分组加密算法，其分组长度、密钥长度都是128bit，算法安全保密强度跟 AES 相当，但是算法不公开，仅以IP核的形式存在于芯片中，需要通过加密芯片的接口进行调用。

采用该算法已经研制了系列芯片、智能IC卡、智能密码钥匙、加密卡、加密机等安全产品，广泛应用于电子政务、电子商务及国民经济的各个应用领域(包括国家政务通、警务通等重要领域)。

4、SM4是分组加密算法

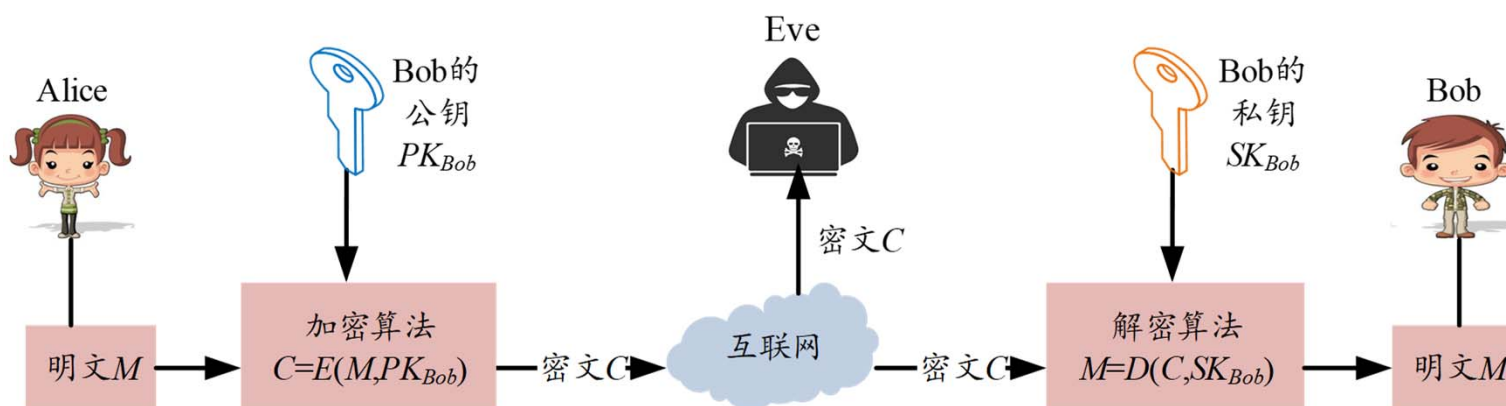
跟SM1类似，是我国自主设计的分组对称密码算法，用于替代DES/AES等国际算法。SM4算法与AES算法具有相同的密钥长度、分组长度，都是128bit。于2012年3月21日发布，适用于密码应用中使用分组密码的需求。

5、SM7是一种分组加密算法

该算法没有公开。SM7适用于非接IC卡应用包括身份识别类应用(门禁卡、工作证、参赛证)，票务类应用(大型赛事门票、展会门票)，支付与通卡类应用(积分消费卡、校园一卡通、企业一卡通、公交一卡通)。

加密算法

非对称加密算法：



加密算法

非对称加密算法特点：

- ✓ 加密和解密使用的是不同的密钥（公钥(公开密钥)和私钥)，每个用户都可以有自己的公钥和私钥，公钥是公开的，私钥是仅自己保存，只要使用一个密钥加密就必须使用另一个密钥解密。

非对称加密算法存在的问题：

- ✓ 加解密算法比较复杂，对于大规模的数据进行加解密，比较影响效率

常用的非对称加密算法：

- ✓ RSA
- ✓ DH
- ✓ ECC
- ✓ Rabin
- ✓ SM2/9

加密算法

2、SM2是非对称加密算法

它是基于椭圆曲线密码的公钥密码算法标准，其密钥长度256bit，包含数字签名、密钥交换和公钥加密，用于替换RSA/DH/ECDSA/ECDH等国际算法。可以满足电子认证服务系统等应用需求，由国家密码管理局于2010年12月17号发布。

SM2采用的是ECC 256位的一种，其安全强度比RSA 2048位高，且运算速度快于RSA。

6、SM9是基于标识的非对称密码算法

用椭圆曲线对实现的基于标识的数字签名算法、密钥交换协议、密钥封装机制和公钥加密与解密算法，包括数字签名生成算法和验证算法，并给出了数字签名与验证算法及其相应的流程。并提供了相应的流程。可以替代基于数字证书的PKI/CA体系。

SM9主要用于用户的身份认证。据新华网公开报道，SM9的加密强度等同于3072位密钥的RSA加密算法，于2016年3月28日发布。

加密算法

3、SM3是一种密码杂凑算法

用于替代MD5/SHA-1/SHA-2等国际算法，适用于数字签名和验证、消息认证码的生成与验证以及随机数的生成，可以满足电子认证服务系统等应用需求，于2010年12月17日发布。

它是在SHA-256基础上改进实现的一种算法，采用Merkle-Damgard结构，消息分组长度为512bit，输出的摘要值长度为256bit。

PKI体系

基本概念:

- ✓ 公钥基础设施 Public Key Infrastructure

工作基础:

- ✓ 通过使用公钥技术(非对称加密算法)和数字签名来确保信息安全
- ✓ 公钥加密技术(非对称加密算法)、数字证书、CA(证书颁发机构)、RA(证书注册机构)组成



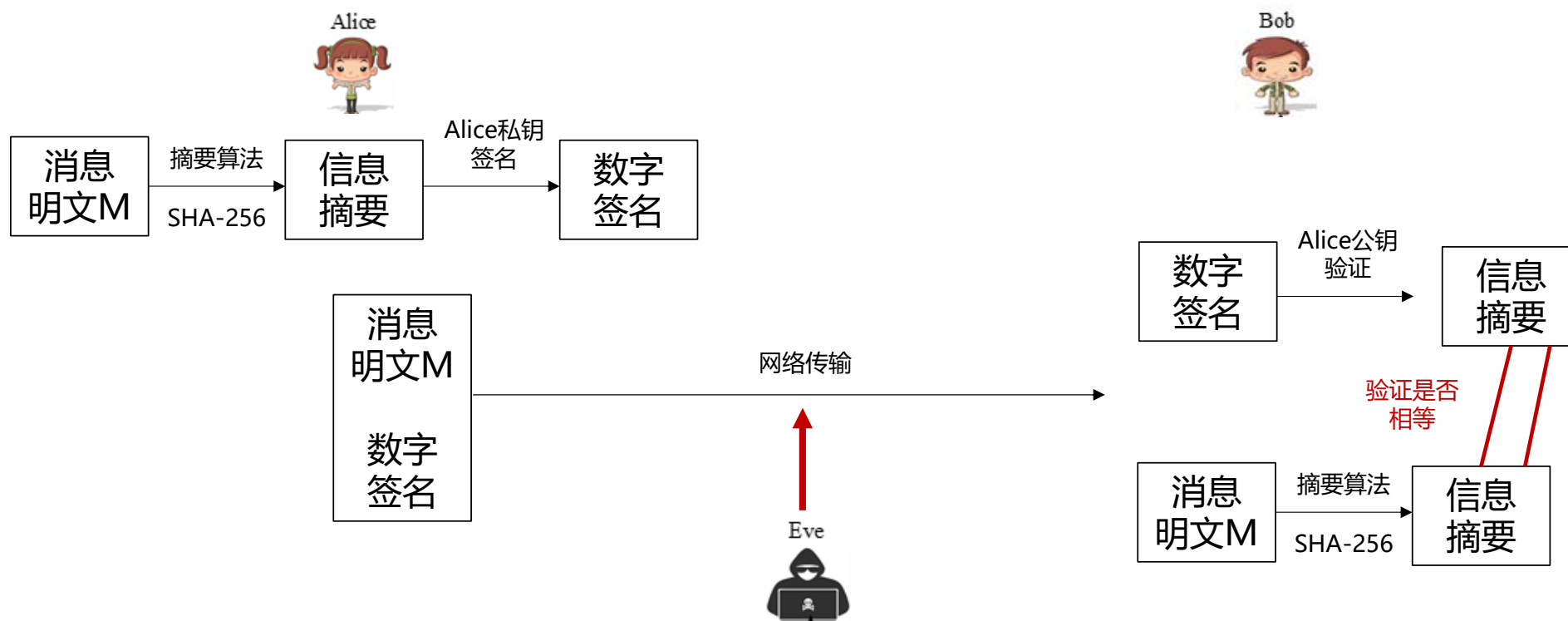
PKI体系

实现的功能:

- ✓身份验证 (数字证书、数字签名)
- ✓数据完整性 (Hash算法)
- ✓数据机密性 (加解密)
- ✓操作不可否认性 (数字证书、数字签名)

PKI体系

身份认证与完整性校验:



PKI体系

身份认证与完整性校验：

- ✓ 发送方Alice首先将原始数据，通过摘要算法(SHA)算出信息摘要，并且用自己的私钥进行签名得到数字签名，将数字签名和原始数据发送给接收方Bob。
- ✓ 接收方Bob收到Alice发来的原始数据和数字签名后，将原始数据通过相同的摘要算法(SHA)得出信息摘要，再使用 Alice的公钥将数字签名解开得出Alice的信息摘要(这里就完成了Alice的身份认证)，比对两个摘要是否一致，如果一致，说明数据在传输过程中没有被修改。

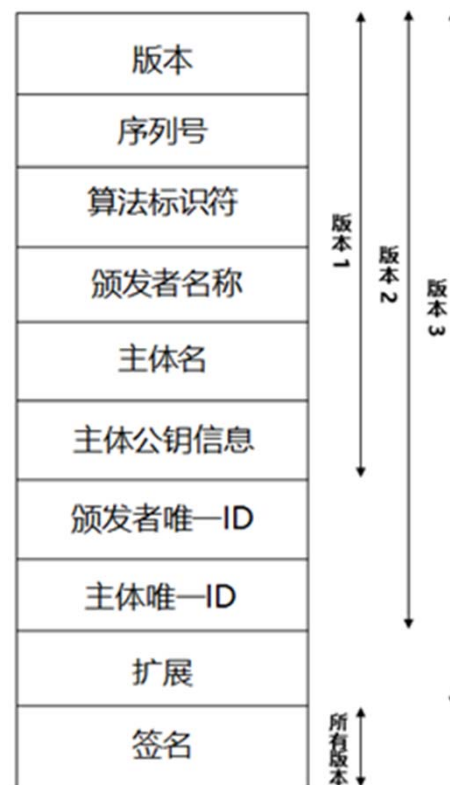
数字证书

作用:

- ✓ 保证密钥的合法性
- ✓ 证书的主体可以是用户、计算机、服务等

组成单元:

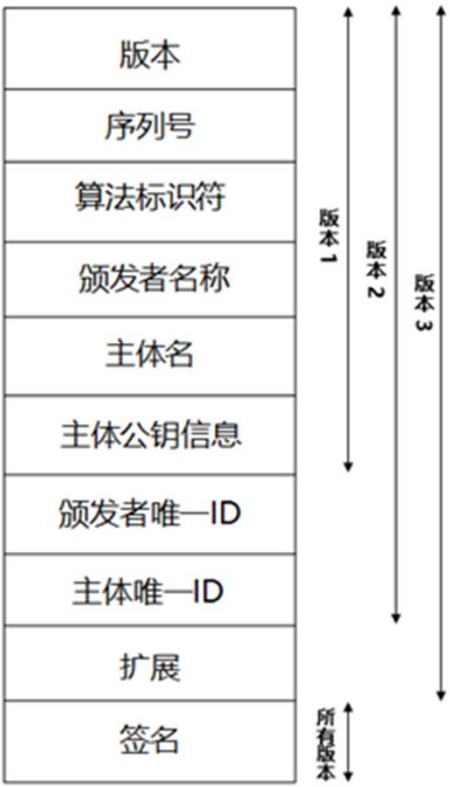
- ✓ 使用者的公钥
- ✓ 使用者的标识
- ✓ 有效期
- ✓ 颁发者的标识信息
- ✓ 颁发者的数字签名



X509证书

第九讲 HTTP协议与HTTPS

数字证书

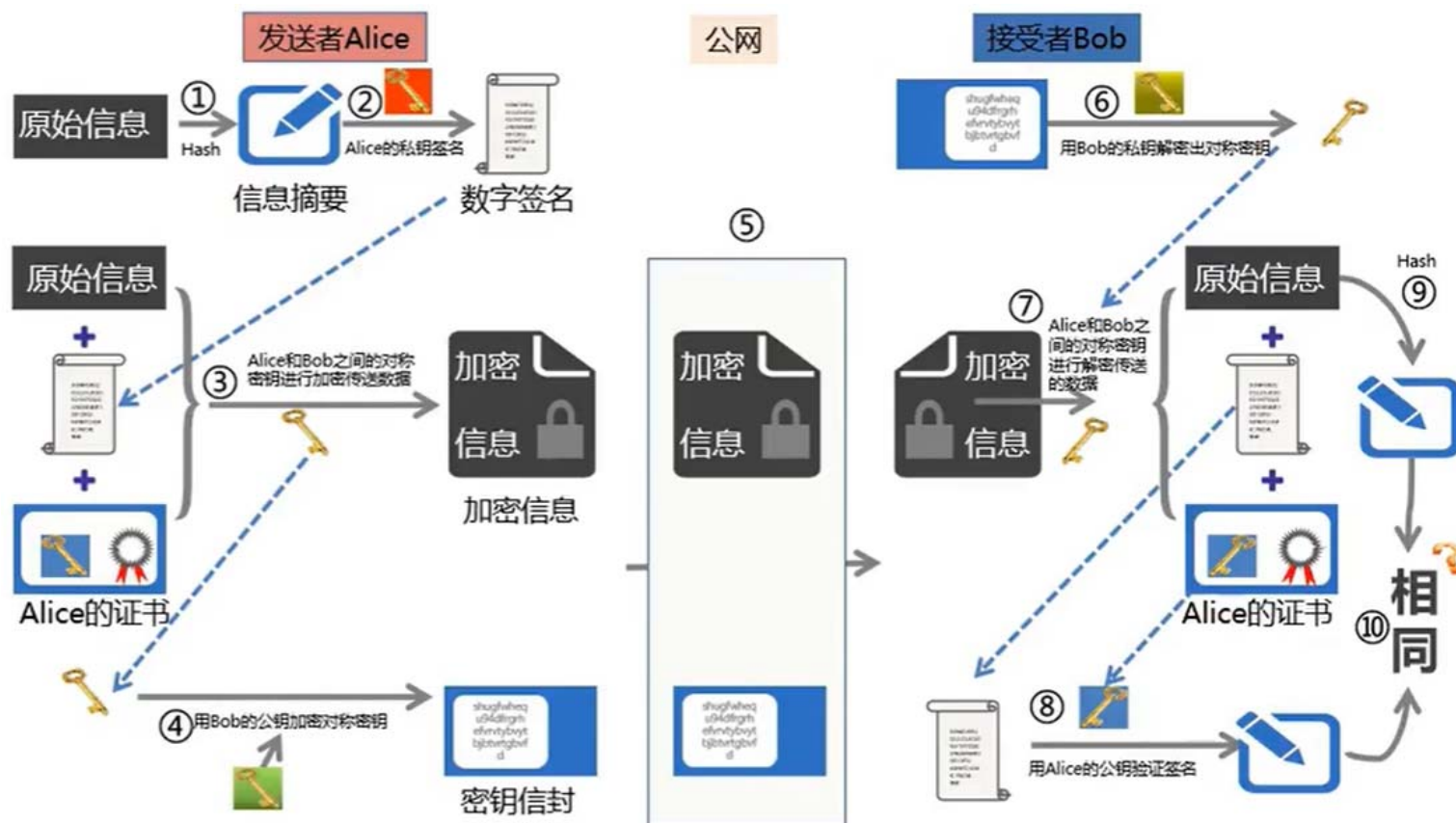


X509证书

```
D:\exercise_cpp\x509\bin\Debug\6_8_1.exe
ca.cer 解析如下:
【版本】version: v3
【序列号】serialNumber: 2b85f2fe98d176994f38bfab9da62d5f
【签名算法】name of algorithm of signature: sha1RSA
【签名算法的参数】parameters of signature: NULL
【签发者标识信息】issuer
Country of issuer: CN
State or province name of issuer: SC
Locality of issuer: CD
Organization name of issuer: UESTC
Organizational Unit name of issuer: CS
Common Name of issuer: testCA
【有效期】validity: 150523034331Z-200523035214Z
【主体标识信息】subject
Country of subject: CN
State or province name of subject: SC
Locality of subject: CD
Organization name of subject: UESTC
Organizational Unit name of subject: CS
Common Name of subject: testCA
【公钥的加密算法】name of algorithm of subjectPublicKey: RSA
【公钥的加密算法参数】parameters of algorithm of subjectPublicKey: NULL
【公钥数据】subjectPublicKey: 003082010a0282010100d49f7db04dd0136c7663ede566d0
a6f7b14227326544bf96cbbc5f7a0c5762fcdcae250aad8dc97cbbba6a4cbc365c5c76fa856932dc9
2a24b63092f72db4215407a20532cc9167a58259442253dcfd38e83438e524f24965cb1fac962106
9baed0858b71b178d602db9e9ce4a800953c17589bad04b0c8112084a5d1cb4b47d3900f7a1686e3
18289445408e0126c5fe973029eb35a74d8ceaaba57a1091f61942047bbf12d3e1c66e9da55558d4
808dd4275aae293ad6073f20078e4566796065e6ddf6157c5dd7d86693c24fa983420616731e673f
0ae0bd866fc148daceb3e03b2aef1cc091f5b707e5d745a5f310e44c5531432ac4b99c47df54accc
9d070203010001
【签发者唯一标识符】issuerUniqueID: 无
【主体唯一标识符】subjectUniqueID: 无
【扩展】extensions: 省略
【签名算法】name of signatureAlgorithm: sha1RSA
【签名算法的参数】parameters of signatureAlgorithm: NULL
【签名结果】signatureValue: 00689be24fac4b849bbf3763b7046561d97f79e5996f2836ef
d272364152489bf16131ae7f3031f751066ad84c61a8912eccc453465d279c12bcf97030e0205bf
d78d059d6b864e6a888fc599e0f5b7336d04a3b6127a714699fc022161f348b48e3137b06c483a05
e26a3ed9820513c7d7372338aad052bc71c34c43ad9b3287d32c175e52790928b607f9fc489e88e
32b844e50dc8918f1505c6b751ec47c0511d3512042f5272429616d2a76b8e62fac74213d9a8ded7
6302ac88ef9b74e87b226f4e2873916d57fe362f9b462c87033504ec82f6ebf8e02cdcb9a25726cd
24a710c5323a77fe2713874532f6992aa78bdb08aa37d0d4b43c381a635e07ef
```

第九讲 HTTP协议与HTTPS协议

HTTPS协议——数据安全传输

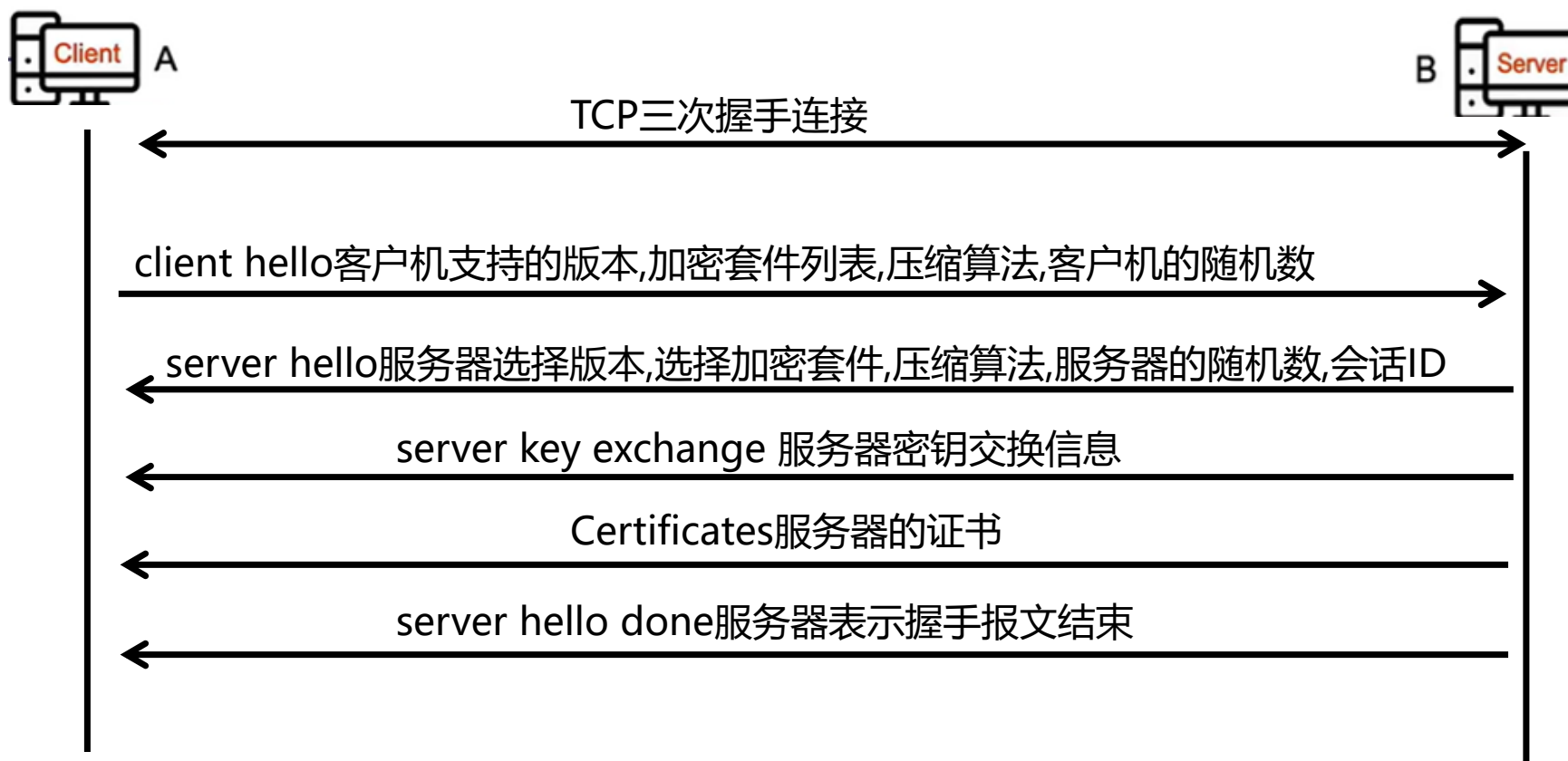


数字证书

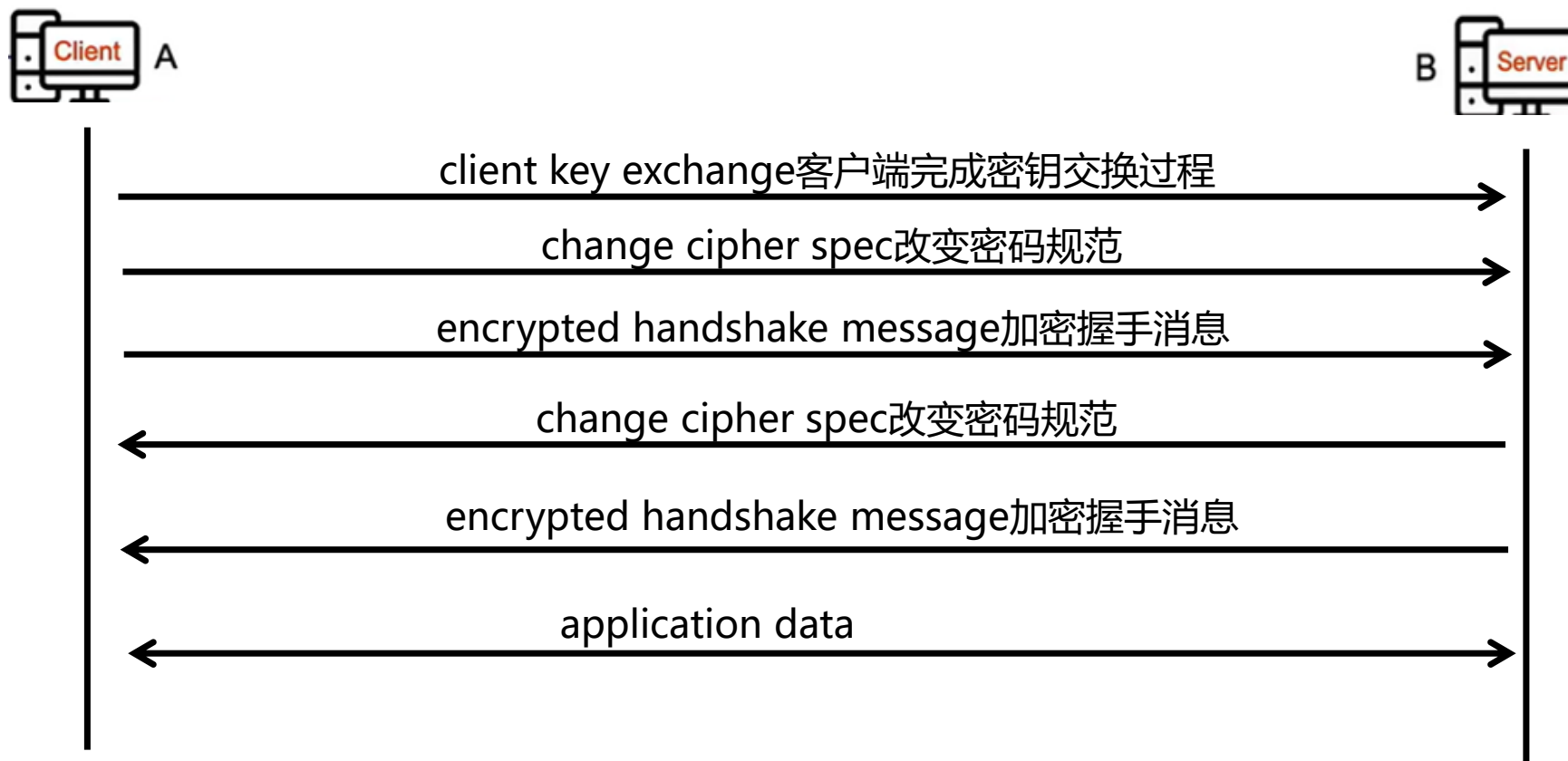
数字证书发机构：

- ✓ CA主要是进行颁发和管理数字证书
- ✓ CA作用的权威性

HTTPS协议交互流程



HTTPS协议交互流程





小结

✓ HTTPS协议